

CMMC 2.0 — Compliance Report

Cisco Secure Workload | Level 2 Lead with Level 1 / Level 3 Deltas

Cisco Secure Workload — Compliance Mapping Series

Version 1.0 (draft — pending SME review)

Table of Contents

Cisco Secure Workload — CMMC 2.0 Compliance Mapping

How to read this report

This report describes how Cisco Secure Workload (CSW) supports a Defense Industrial Base (DIB) organisation's posture against **CMMC 2.0** (Cybersecurity Maturity Model Certification). Default depth is written for **Level 2** because that's where the technical substance — and the bulk of CSW alignment — lives. Level 1 and Level 3 deltas are called out where the work materially changes.

Why CMMC and not just NIST 800-171? CMMC 2.0 doesn't invent new controls. It is the DoD's *certification* mechanism that your organisation has implemented the controls already required under DFARS 252.204-7012:

- **Level 1 (Foundational, 15 safeguards)** — implements FAR 52.204-21. Self-attested annually. Required for FCI.
- **Level 2 (Advanced, 110 controls)** — implements all 110 controls of NIST SP 800-171 Rev 2. Self-assessed (some contracts) or third-party-assessed via a C3PAO every 3 years. Required for CUI.
- **Level 3 (Expert, ~134 controls)** — Level 2 plus selected NIST SP 800-172 enhancements. Government-led assessment.

Companion document. The accompanying *CMMC 2.0 Technical Runbook* walks through CUI scope labelling, per-family implementation steps for Level 2, and the Level 1 / Level 3 deltas. Read this report for the audit-narrative view; read the runbook for the deployment view.

Important. CMMC Level 2 assessment is performed by a Certified Third-Party Assessor Organisation (C3PAO). Nothing in this report substitutes for the System Security Plan (SSP), Plan of Action & Milestones (POA&M), or the C3PAO engagement. CSW supplies the technical evidence the assessment depends on; the SSP documents the process around that evidence.

How to read the Coverage column

Direct means Secure Workload produces the primary evidence artifact for that row — segmentation, policy, flow and process telemetry, inventory, vulnerability and reachability, or forensic reconstruction. Direct is still evidence, not an attestation.

Supporting means Secure Workload contributes an input that feeds or complements another control, tool, or process — detection input only, reconciled against an external register, or one log source among several.

Evidence Required means Secure Workload has no record for that row. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

Every report in this set now uses the same three coverage words — Direct, Supporting, and Evidence Required. Coverage describes what evidence Secure Workload produces; it never means the control is passed.

1. Executive Summary

CMMC 2.0 final rule (DFARS 252.204-7021 / 32 CFR Part 170) became effective December 16, 2024. DoD contracts will phase in CMMC requirements over the subsequent three years. For the bulk of the DIB, the operative target is **Level 2**, which implements all 110 controls of NIST SP 800-171 Rev 2.

CSW provides direct technical coverage for six of NIST 800-171's fourteen control families (AC, AU, CM, RA, SC, SI), supports four more (CA, IA, IR evidence, MA), and is explicitly out of scope for four (AT, MP, PE, PS).

What CSW changes for a CMMC Level 2 programme:

- **CUI Scope Boundary (foundational).** Per-enclave segmentation with deny-by-default at the workload identity layer. Workload labels (`cui_scope`, `cui_role`, `contract_id`, `enclave`) make the boundary enforceable and auditable.
- **AC family.** Workload-level access enforcement (3.1.1), inter-enclave information-flow control (3.1.3), external connection verification (3.1.20), publicly-accessible system inventory (3.1.22).
- **AU family.** Per-flow + per-process telemetry forwarded to SIEM (3.3.1), action traceability via process attribution + SIEM identity correlation (3.3.2).
- **CM family.** Daily configuration baseline per workload (3.4.1), drift detection with change-ticket attribution (3.4.3 / 3.4.4), least-functionality review via 90-day-no-flow port reports (3.4.6).
- **RA family.** Continuous CVE inventory per CUI workload (3.11.2), patch SLA tracking and POA&M linkage (3.11.3), compensating- control register for deferred patches.
- **SC family.** Per-enclave segmentation with deny-by-default (3.13.1, 3.13.6), public-component scope isolation (3.13.5), ADM-derived as-observed architecture diagrams (3.13.2).

- **SI family.** Behavioural detection rules (3.14.2, 3.14.6), conversation-graph anomaly detection (3.14.6), threat-intel- enriched CVE prioritisation (3.14.3), unauthorised-use detection (3.14.7).

What CSW does not change. CSW does not author the SSP or POA&M, does not perform the C3PAO assessment, does not address AT (training), MP (media), PE (physical), or PS (personnel). Identity is upstream. CSW is the technical evidence engine the SSP documents around.

2. Compliance Posture Summary

Family	Title	Coverage	CSW contribution (Level 2)
AC	Access Control	Direct	Workload-level enforcement; inter-enclave flow control
AT	Awareness and Training	Evidence Required	HR / training
AU	Audit and Accountability	Direct	Per-flow + per-process telemetry to SIEM
CA	Security Assessment	Supporting	Continuous monitoring evidence
CM	Configuration Management	Direct	Baseline + drift + least-functionality review
IA	Identification and Authentication	Supporting	Workload-side enforcement; identity upstream
IR	Incident Response	Direct (evidence)	Six-artefact reconstruction bundle
MA	Maintenance	Supporting	Limited
MP	Media Protection	Evidence Required	Media-handling process
PE	Physical Protection	Evidence Required	Facilities
PS	Personnel Security	Evidence Required	HR
RA	Risk Assessment	Direct	Continuous CVE + reachability + POA&M linkage
SC	System and Communications Protection	Direct	Per-enclave boundary + segmentation + deny-by-default

Family	Title	Coverage	CSW contribution (Level 2)
SI	System and Information Integrity	Direct	Detection rules + anomaly detection + threat intel

Posture takeaway. Direct on six of fourteen families (AC, AU, CM, RA, SC, SI), supporting on four (CA, IA, IR evidence, MA), out of scope on four (AT, MP, PE, PS). This is consistent with CSW's positioning as a workload-protection platform: it does the workload-tier jobs well and explicitly defers identity, media, physical, and personnel scope to the appropriate owners.

3. Mapping Table — CMMC L2 Practice → CSW Capability → Evidence Artefact

Practice	Topic	CSW capability	Evidence artefact (audit-ready)
AC.L1/L2-3.1.1	Limit system access to authorised users / processes / devices	Workload-level deny-by-default segmentation per enclave	Workspace export per enclave + simulation → enforcement log
AC.L1/L2-3.1.2	Limit access to authorised functions / transactions	Allow-list per documented system function	Per-enclave allow-list with rule provenance
AC.L2-3.1.3	Control flow of CUI	Inter-enclave flow allow-list + reconciliation against SSP	Inter-enclave flow CSV + delta vs. SSP
AC.L2-3.1.20	Verify and control external connections	Egress allowlist + alert on net-new external destinations	Egress allowlist + alert log
AC.L2-3.1.22	Control CUI on publicly-accessible systems	Internet-reachability query + scope review	Internet-exposure inventory
AU.L2-3.3.1	Create audit records	Per-flow + per-process telemetry to SIEM	SIEM forwarding configuration + sample audit record
AU.L2-3.3.2	Action traceability to individual users	Process attribution + SIEM identity correlation	Sample event with process + identity attribution
AU.L2-3.3.4/5	Alert on audit failure; correlate audit data	Forwarder health alert + SIEM correlation rules	Alert configuration + correlation rule export

Practice	Topic	CSW capability	Evidence artefact (audit-ready)
AU.L2-3.3.8	Protect audit information	SIEM-side immutable storage; CSW RBAC	SIEM retention configuration + CSW RBAC export
AU.L2-3.3.9	Limit audit-log management functionality	CSW RBAC for audit-management roles	Role definition export
CM.L2-3.4.1	Establish configuration baselines	Daily snapshot per workload (OS, packages, ports, processes)	Baseline export per workload
CM.L2-3.4.2	Establish security configuration settings	(Hardening upstream; CSW verifies via baseline)	Baseline + drift report
CM.L2-3.4.3/4	Track and approve changes	Daily diff + change-ticket attribution	Diff log with disposition column
CM.L2-3.4.6	Employ principle of least functionality	Listening-port + service inventory + 90-day-no-flow review	Quarterly least-functionality review
CM.L2-3.4.7	Restrict use of nonessential programs / functions	Software allow-list + (L3) behavioural prevention	Allow-list deviation log
RA.L2-3.11.2	Scan for vulnerabilities	Continuous CVE inventory per CUI workload	Per-CUI-workload CVE list dated to scan cadence
RA.L2-3.11.3	Remediate vulnerabilities	Patch SLA tracking + compensating-control register + POA&M linkage	Patch SLA trend + compensating-control register + POA&M cross-reference
SC.L2-3.13.1	Boundary protection	Per-enclave segmentation enforcement	Workspace export per enclave
SC.L2-3.13.2	Architectural designs supporting effective security	ADM-derived as-observed architecture	ADM dependency graph per enclave
SC.L2-3.13.5	Subnetworks for publicly-accessible components	Public-component scope isolation	Public-component scope documentation + policy export
SC.L2-3.13.6	Deny by default; permit by exception	Workload-level deny-by-default (native	Per-enclave policy export

Practice	Topic	CSW capability	Evidence artefact (audit-ready)
		CSW posture)	
SC.L2-3.13.7	Prevent split tunneling on remote devices	Detective alert on split-tunnel patterns	Split-tunnel alert log
SI.L2-3.14.1	Identify, report, and correct system flaws	CVE inventory + drift + SIEM routing	CVE list + drift log + SIEM forwarding
SI.L2-3.14.2	Provide protection from malicious code	Behavioural rules layered with endpoint AV	Behavioural rule catalogue + sample alert
SI.L2-3.14.3	Monitor system security alerts and advisories	Threat-intel-enriched CVE prioritisation	Enrichment configuration + sample enriched CVE
SI.L2-3.14.6	Monitor organisational systems for attacks	Per-workload flow telemetry + behavioural rules + anomaly detection	Detection rule catalogue + anomaly alert log
SI.L2-3.14.7	Identify unauthorised use	Process telemetry + identity-aware policy	Sample unauthorised-use detection
IR.L2-3.6.1/2/3	Incident response process	Six-artefact incident dossier	Sample dossier per CUI-scope incident

4. Out-of-Scope and Complementary Controls

CSW does **not** address the following families / practices; reference the noted complementary controls.

Family / Practice	Owner	Complementary control
AT — Awareness and Training	HR + Security training	LMS + phishing simulation
IA — Identification and Authentication	Identity / PAM team	AD/LDAP, PAM (CyberArk, BeyondTrust), MFA
MA — Maintenance	Operations	Maintenance procedures and approval process
MP — Media Protection	Operations	Media-handling, sanitisation, transport
PE — Physical Protection	Facilities	PSP enclosure, badge access, visitor escort
PS — Personnel Security	HR	Background investigation, screening, termination

Family / Practice	Owner	Complementary control
AT.L2-3.2.x training-related practices	HR + Security training	LMS + role-based training
IA.L2-3.5.x credential management	Identity / PAM team	Credential vault, MFA enforcement
SC.L2-3.13.16 protect CUI confidentiality at rest	Crypto / Storage SME	Encryption-at-rest configuration

CSW's role in a complete CMMC programme is the workload-tier evidence engine for the technical families. The SSP and POA&M document the process around that evidence; identity, media, physical, and personnel are explicitly upstream.

5. Suggested Next Steps

For DIB organisations targeting CMMC Level 2 with CSW:

1. **Confirm CUI scope first.** The CUI scope determination is the single most consequential decision in a CMMC engagement. The wider the scope, the larger the assessment. Get the CUI-handling owner to sign off the scope before deploying CSW labels.
 2. **Pilot on the AC + SC families.** Workload-level segmentation per enclave is the foundation everything else builds on. The simulation → enforcement workflow gives you weeks to refine without breaking systems.
 3. **Wire CSW telemetry into the SIEM you already have.** AU.L2- 3.3.1 / 3.3.2 expect logs in your SIEM with action traceability. CSW supplies the workload-tier feed; the SIEM is where correlation and retention live.
 4. **Tie drift detection to your change-management ticketing day one.** CM.L2-3.4.3 / 3.4.4 expect change tracking; orphan changes (CSW-detected, ticket-absent) become unauthorised-change candidates that the C3PAO will ask about.
 5. **Link CSW vuln IDs to POA&M items.** RA.L2-3.11.3 expects a tracked remediation programme; the POA&M is the artefact. CSW produces the per-workload CVE feed; cross-reference into POA&M so the assessment trail is contiguous.
 6. **Build the SSP appendix once.** The SSP describes how each practice is implemented; CSW evidence (workspace exports, baseline exports, CVE lists, dossier templates) sits in the appendix referenced from each practice section. Build the appendix structure once and refresh per cycle.
 7. **Plan SME review.** This document is a v1 mapping. Before being relied upon in a formal C3PAO engagement, route to a CMMC Registered Practitioner Organisation (RPO) for assessment guidance currency and to a current Cisco Secure Workload SE for product-capability accuracy.
-

6. Disclaimer

This report and its companion runbook describe how Cisco Secure Workload capabilities can support a CMMC 2.0 programme at Level 2 (with Level 1 and Level 3 deltas). They are **not** legal or compliance advice and do not constitute a finding of compliance.

Specifically:

- The DoD publishes the authoritative CMMC 2.0 text at <https://dodcio.defense.gov/CMMC/>. The DCMA Defense Industrial Base Cybersecurity Assessment Center (DIBCAC) and the Cyber AB publish authoritative assessment guidance. Always validate against the **current effective rule** (DFARS 252.204-7021 / 32 CFR Part 170) and against any DoD class deviations.
- CMMC Level 2 assessment is performed by a Certified Third-Party Assessor Organisation (C3PAO) or, for limited contracts, by self-assessment. Nothing in this document substitutes for the SSP, POA&M, or the C3PAO engagement.
- Mapping a CSW capability to a 800-171 practice does not by itself satisfy the practice. The C3PAO will look for documented process, evidence cadence, and management review behind the technical implementation.
- CSW does not address AT, MP, PE, or PS families. Reference your HR, media-handling, physical-protection, and personnel-security programmes for those.

This document should receive subject-matter-expert review for both CMMC 2.0 currency and current Cisco product capability before being used in a customer engagement.